

Vulnerability Assessment

Work Sample by Misti Burton

Scenario

This scenario is based on a fictional company as part of Coursera's Google Cybersecurity Professional Certificate.

You are a newly hired cybersecurity analyst for an e-commerce company. The company stores information on a remote database server, since many of the employees work remotely from locations all around the world. Employees of the company regularly query, or request, data from the server to find potential customers. The database has been open to the public since the company's launch three years ago. As a cybersecurity professional, you recognize that keeping the database server open to the public is a serious vulnerability.

You are tasked with completing a vulnerability assessment of the situation to communicate the potential risks to decision makers at the company. You must create a written report that explains how the vulnerable server is a risk to business operations and how it can be secured.

My tasks:

1. *Review information about the vulnerable server, including the provided system description and scope.*
2. *Perform risk assessment (explanation of information system purpose, identification of potential threat sources, events, and risk levels).*
3. *Propose security recommendations that align with best practices from NIST SP 800-30.*

Work Sample: Vulnerability Assessment

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2024 to August 2024. NIST SP 800-30 is used to guide the risk analysis of the information system.

Purpose

- **Database Value:** The database server holds critical customer data and historical transaction records, making it vital for daily sales operations and customer research.
- **Importance of Securing Data:** Securing this data is essential to protect sensitive information, prevent costly data breaches, and maintain regulatory compliance and customer trust.
- **Impact if Disabled:** If the server were disabled or compromised, business operations would come to a halt, leading to lost revenue, reputational damage, and severe operational disruption.

Risk Assessment

Threat Source	Threat Event	Likelihood	Severity	Risk
External Cybercriminals	Exploiting publicly open database port to exfiltrate sensitive customer and transaction data.	3	3	9
Malicious Bots & Automated Scanners	Performing brute-force authentication or injection attacks against unsegmented MySQL server.	3	2	6
Untrained / Compromised Remote Employees	Connecting via unencrypted public networks or leaking access credentials due to lack of network controls.	2	3	6

Approach

The selected threat sources and events focus on external attackers exploiting public database access, unauthorized data exfiltration, and opportunistic malicious scans. These specific risks were chosen because the database contains critical customer data and historical transaction records directly exposed to the public internet without authentication controls. A compromise in any of these areas would severely disrupt daily sales operations, violate regulatory compliance, and cause irreparable reputational damage to the company.

Security Recommendations

To remediate the public database exposure, strict network access control lists (ACLs) and firewall rules must be implemented to restrict database access exclusively to authorized internal IP addresses and VPN connections. A Virtual Private Network (VPN) with mandatory multi-factor authentication (MFA) should be deployed for remote employees querying customer records. Furthermore, public key infrastructure (PKI) and robust database access control mechanisms should be enforced to encrypt internal traffic and prevent unauthorized exfiltration of sensitive records.

1. **Network Segmentation and VPN Access Control:** Restricting the database server from direct public internet exposure is the most critical immediate priority. Transitioning remote employee access to a secured, authenticated VPN protected by MFA immediately eliminates exposure to automated internet scans, brute-force attacks, and unauthorized external connections.
2. **Least Privilege & Strong Authentication Enforcement:** Restricting database privileges ensures employees and applications can only access specific data required for their roles. Enforcing strong authentication controls and regular key management prevents credential abuse and limits potential damage if a remote worker's device becomes compromised